

>_ PASSIVE OSINT INTELLIGENCE PROFILE

SPOOKY PASTA

Target: **GitHub, Inc.** — a Microsoft company

 TEAM PEN DRAGONS

Why GitHub?

The perfect test case for one question: how much can an outsider learn from public data alone?



A hard target

A Microsoft company storing the world's code. Security is core to their business — finding exposure here means something.



A real footprint

Big enough to have serious infrastructure, dozens of vendors, and many employees — plenty to actually analyze.



Fully public

Everything about them is genuinely public, so we could do this ethically — without ever crossing a line.

PART 1

Technical Footprint

Presented by **Henry**



GitHub Technical Footprint

Domain, DNS & Mail Infrastructure

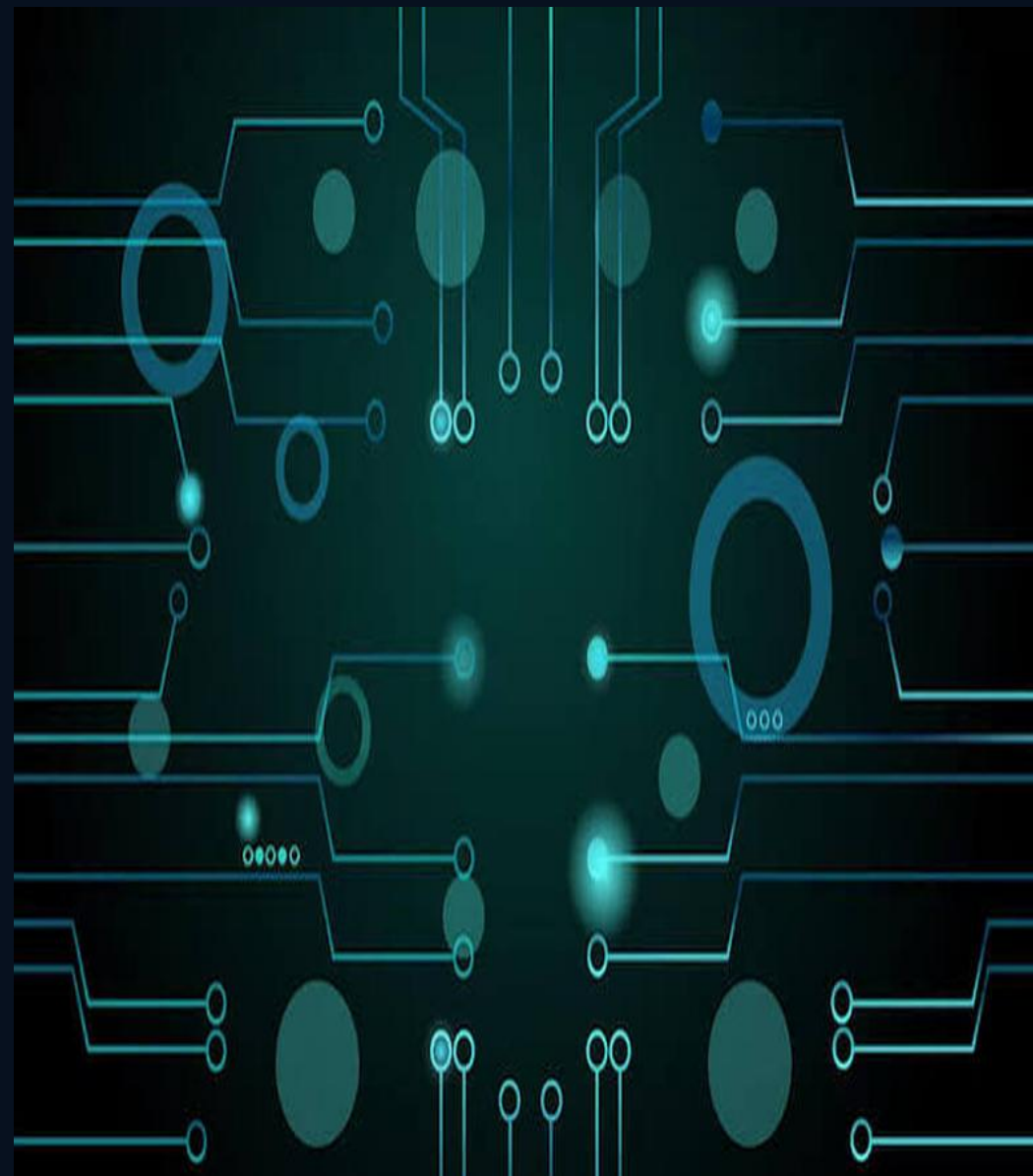
Using passive OSINT to show what public records reveal about a major organization — without logging in, scanning aggressively, or touching internal systems.

WHOIS

DNS

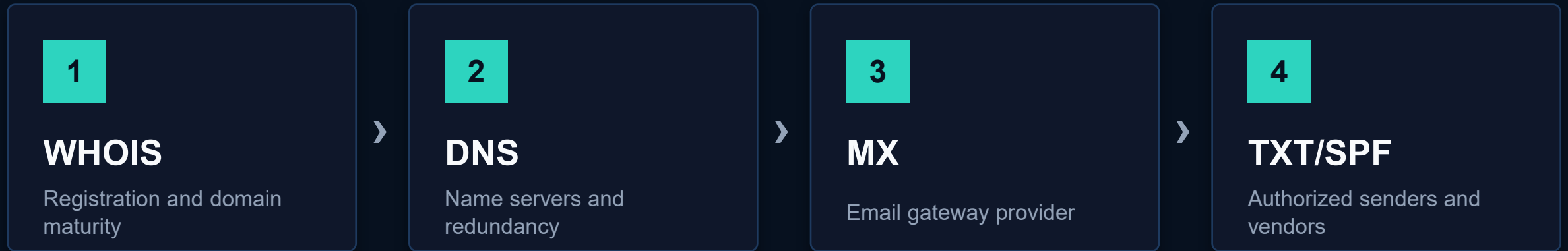
MX

SPF/TXT



Passive OSINT Workflow

Goal: convert public records into clear, defensible findings.



Key rule: this is passive reconnaissance — the evidence came from public records and standard lookup tools.

WHOIS: Domain Ownership & Maturity

What the public registration record tells us.

Registrar

MarkMonitor Inc.

Created

October 9, 2007

Expires

October 9, 2026

- MarkMonitor is commonly used by large enterprises for domain protection and brand management.
- A long-lived domain and current renewal suggest mature, professional domain management.
- WHOIS does not show a vulnerability by itself — it establishes baseline ownership and history.

The screenshot shows the 'who.is' WHOIS Domain Lookup interface. The domain 'github.com' is entered in the search bar. The results show the domain is registered to MarkMonitor Inc. with a creation date of October 9, 2007, and an expiration date of October 9, 2026. The nameservers are listed in a table below.

Hostname	IP Address
dns1.p08.nsone.net	198.51.44.8
dns2.p08.nsone.net	198.51.45.8
dns3.p08.nsone.net	198.51.44.72
dns4.p08.nsone.net	198.51.45.72
ns-1283.awsdns-32.org	205.251.197.3
ns-1707.awsdns-21.co.uk	205.251.198.171
ns-421.awsdns-52.com	205.251.193.165

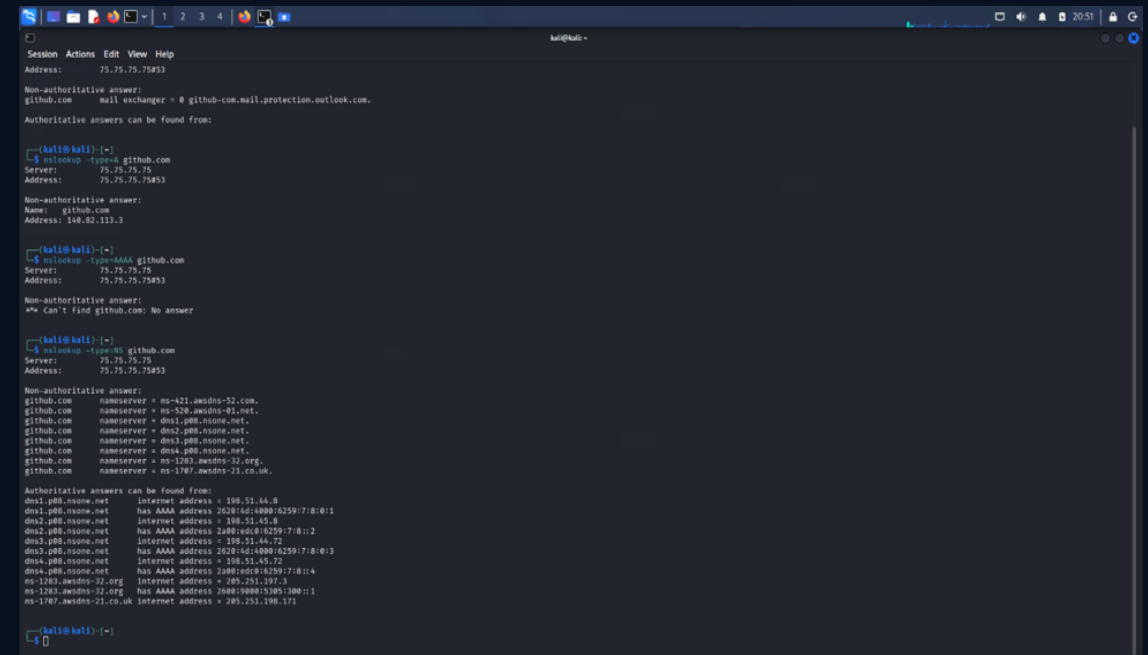
DNS: Redundant Name Servers

DNS is the Internet phone book: it maps names like github.com to network destinations.

Observed providers

NSOne + Amazon Route 53

- Authoritative name servers answer DNS questions for github.com.
- GitHub has multiple name servers across different providers.
- This supports availability: if one DNS path fails, others can still resolve the domain.
- Redundancy is a resilience signal, not a weakness.



```
Session Actions Edit View Help
Address: 75.75.75.75453

Non-authoritative answer:
github.com mail exchanger = 0 github-com.mail.protection.outlook.com.
Authoritative answers can be found from:

[hal@kali:~]$ nslookup -type=A github.com
Server: 75.75.75.75
Address: 75.75.75.75453

Non-authoritative answer:
Name: github.com
Address: 140.82.113.3

[hal@kali:~]$ nslookup -type=AAAA github.com
Server: 75.75.75.75
Address: 75.75.75.75453

Non-authoritative answer:
** Can't find github.com: No answer

[hal@kali:~]$ nslookup -type=NS github.com
Server: 75.75.75.75
Address: 75.75.75.75453

Non-authoritative answer:
github.com nameserver = ns-421.awdns-52.com.
github.com nameserver = ns-520.awdns-01.net.
github.com nameserver = dns1.p08.nsone.net.
github.com nameserver = dns2.p08.nsone.net.
github.com nameserver = dns3.p08.nsone.net.
github.com nameserver = dns4.p08.nsone.net.
github.com nameserver = ns-1203.awdns-32.org.
github.com nameserver = ns-1707.awdns-21.co.uk.

Authoritative answers can be found from:
dns1.p08.nsone.net internet address = 190.55.44.8
dns1.p08.nsone.net has AAAA address = 2620:f4:6000:6259:7:8::1
dns2.p08.nsone.net internet address = 190.55.45.8
dns2.p08.nsone.net has AAAA address = 2a00:ed08:6259:7:8::2
dns3.p08.nsone.net internet address = 190.55.44.72
dns3.p08.nsone.net has AAAA address = 2620:f4:6000:6259:7:8::3
dns4.p08.nsone.net internet address = 190.55.45.72
dns4.p08.nsone.net has AAAA address = 2a00:ed08:6259:7:8::4
ns-1203.awdns-32.org internet address = 205.251.197.2
ns-1203.awdns-32.org has AAAA address = 2a00:ee00:5305:300::1
ns-1707.awdns-21.co.uk internet address = 205.251.198.171

[hal@kali:~]$
```

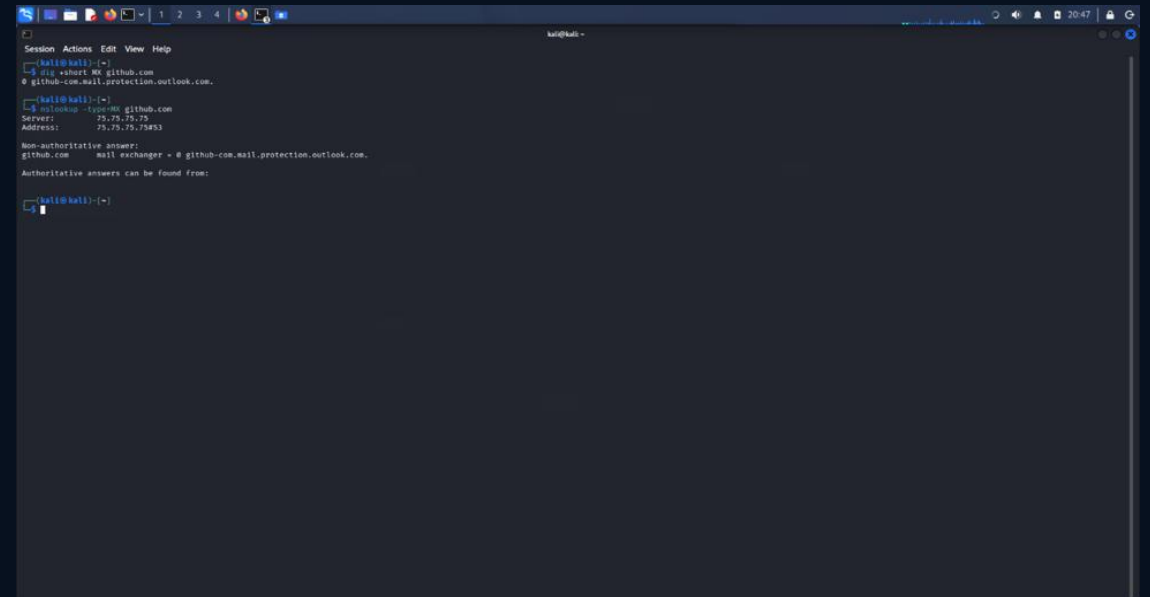
MX: Mail Routing

MX records show where inbound email for the domain is handled.

Mail exchanger

github-com.mail.protection.outlook.com

- MX means Mail Exchange.
- The MX lookup points to Microsoft Exchange Online Protection.
- This suggests Microsoft is used as a mail security gateway for inbound email.
- Security value: email routing tells us which provider filters their mail.

A terminal window titled 'kali@kali' showing a series of commands and their outputs. The user enters 'dig +short mx github.com', which returns 'github-com.mail.protection.outlook.com.'. Then, they enter 'nslookup -type=mx github.com', which returns 'Server: 75.75.75.75' and 'Address: 75.75.75.75493'. Below this, it says 'Non-authoritative answer: github.com mail exchanger = 0 github-com.mail.protection.outlook.com.' and 'Authoritative answers can be found from:'.

```
kali@kali:~$ dig +short mx github.com
github-com.mail.protection.outlook.com.

kali@kali:~$ nslookup -type=mx github.com
Server:      75.75.75.75
Address:     75.75.75.75493

Non-authoritative answer:
github.com  mail exchanger = 0 github-com.mail.protection.outlook.com.

Authoritative answers can be found from:
```

SPF/TXT: Authorized Email Senders

SPF helps receiving mail servers decide whether an email is allowed to come from a domain.

SPF = Sender Policy Framework

Like an official guest list for email servers. If an email claims to come from GitHub, the receiving server checks whether that sender is on GitHub's public SPF list.

Vendors visible in the SPF/TXT ecosystem

Microsoft

Salesforce

Zendesk

Google

Mailchimp

Marketo

SendGrid

Why It Matters: Vendor Footprint

Public records can reveal the support, marketing, and customer-management stack.

CRM

Customer Relationship Management: software used to manage customers, support, sales, and communication history. Salesforce is a common CRM example.

OSINT value

- Defenders can inventory exposed public dependencies.
- Blue teams can verify SPF, DKIM, DMARC and vendor authorization.
- Attackers could misuse vendor knowledge to craft more convincing phishing lures.

CRM

Salesforce

Support

Zendesk

Marketing

Mailchimp

Automation

Marketo

Email API

SendGrid

Identity

Microsoft

PART 2

Exposed Services & The People Behind Them

Presented by **Matthew**



Exposed Services

Infrastructure can be found. People can be targeted.

 EXPOSED SERVICES (Shodan)

80

HTTP

OPEN

443

HTTPS

OPEN

nginx

Ubuntu Linux

WEB STACK

Content-Security-Policy: unsafe-inline observed (to verify)



FIND

Open services



GATHER

Information



IDENTIFY

People



EXPLOIT

Human factor

Security isn't just about systems. **It's about people.**

Subdomains & Certificates

Tool: Censys — certificate transparency reveals subdomains, including internal-sounding services.

Subdomain	Issuer	Validity
redundant.cloudbees.github.com	DigiCert TLS RSA SHA256 2020 CA1	Dec 10, 2025 – Dec 10, 2026
SCCM-reverseproxy.github.com	Microsoft Azure RSA TLS Issuing CA 03	Aug 15, 2024 – Aug 15, 2026

Findings

Censys surfaced several GitHub-related certificates and subdomains. The “Untrusted” label in Censys means internal/private — not insecure. SCCM-reverseproxy hints at an internal management service.

Host Profile

Tool: Shodan — general information and web technologies visible on public-facing hosts.

Hostnames	github.com · github.io · githubusercontent.com
Country / City	United States · San Francisco
Organization	GitHub, Inc.
ISP	Fastly, Inc.
ASN	AS54113

Open Ports

80

HTTP

443

HTTPS

Web Technologies

NGINX

Ubuntu

Fastly

Security header: Content-Security-Policy unsafe-inline (to verify)

Executive Digital Footprint

Tool: Epieos — passively mapping an executive's public footprint from a corporate email.



Vladimir Fedorov

Chief Technology Officer, GitHub

vfedorov@github.com

- Epieos maps linked public accounts, registered services, and breach exposure tied to a corporate email.
- Reported at the summary level only — e.g. “this executive's corporate email appeared in N public breaches.”
- We deliberately did NOT collect personal emails, passwords, or raw breach data. That restraint is part of the ethics.

PART 3

Job Posting Intelligence

Presented by **Nigel**



Beyond Recruitment

Job postings are more than hiring tools — they reveal strategy.



Strategic Intent

Postings reveal strategic technical direction and expansion goals, not just open roles.



Expansion Evidence

Ongoing hiring for specific projects signals active expansion and maturation of core platforms.

Tech Stack Intelligence

What GitHub's open roles reveal about where they're investing.



Blackbird Search

New Rust-powered search engine scaling up — heavy ongoing investment in code search.



GitHub Copilot

Strategic investment in AI-driven development tooling.



Codespaces

Expansion into new global infrastructure markets (e.g. Japan).

Reconnaissance Risks

The unintended consequences of public disclosures.



Profile Harvesting

Public employee profiles make key engineers identifiable. Named: Angela W., Parth Sehgal, Casey Benson.



Email Formats

Standardized corporate email structure is predictable once a single profile is found.



Internal Services

Naming like “SCCM-reverseproxy” reveals internal architecture details.



Social Engineering

Rich job-post context enables highly realistic, effective phishing lures.

The Bigger Picture

Mapping the roadmap.



Individually, these findings seem harmless. Together, they provide a comprehensive roadmap for highly targeted phishing campaigns and strategic espionage.

By connecting technical needs with personnel roles, attackers gain a high-confidence blueprint of the organization's inner workings.

PART 4

Recommendations & Ethics



Presented by **Jamie**

Recommendations

Simple, low-cost steps that shrink the public attack surface.



Tighten DMARC

Move org DMARC to p=reject; confirm SPF/DKIM alignment.



Rename internal subdomains

Reduce exposure of names like SCCM-reverseproxy.



Limit job-post detail

Keep specific internal tech out of public postings.



Monitor CT logs

Watch certificate transparency for new subdomains.



Review exposed services

Re-check Shodan-visible services on a schedule.



Audit repos & rotate secrets

Scan public repos; rotate any exposed tokens.

Methods & Ethics

Everything was passive, public, and defensive.

Our ground rules

- Public sources only — no scanning beyond passive lookups.
- No login attempts, no social engineering, no contact with anyone.
- No interaction with protected systems.
- Executive findings reported at summary level only.
- Purpose was defensive: help reduce the exposed attack surface.

Aligned to recognized standards

NIST CSF 2.0

Cybersecurity Framework

NIST SP 800-115

Security Testing & Assessment

OWASP

Testing Guide

MITRE ATT&CK

Reconnaissance tactics

Thank you